Báo cáo kiểm thử bảo mật

Chế độ: gemini-top10-analysis-extractive

Thời điểm UTC: 2026-10-09T04:08:37.476054+00:00

Số phát hiện đầu vào: 1

Phạm vi khắc phục: OWASP Top 10:2025 - Web Application Security

Phạm vi và giới hạn

- Chỉ đề xuất cho CWE có ánh xạ trực tiếp trong OWASP Top 10:2025 và có bằng chứng đầu vào.

- Gemini chỉ chọn ID đoạn gốc; không tự viết, dịch hoặc bổ sung hướng dẫn khắc phục.

- Trích nguyên văn không chứng minh hướng dẫn phù hợp. Cần người kiểm tra trước khi áp dụng.

- Kho Cheat Sheet Series do người dùng tải từ nguồn chính thức. Hash kiểm tra tính nhất quán với lúc ingest, không xác thực độc lập nguồn tải.

- Nguồn hướng dẫn: OWASP Cheat Sheet Series, CC BY-SA 4.0; https://creativecommons.org/licenses/by-sa/4.0/. Trích đoạn giữ nguyên Markdown gốc.

- Không truy cập source code/database, không chạy quét, tự sửa code hoặc retest.

- Phân tích/tổng quan tiếng Việt do Gemini sinh; ID và trích đoạn đầu vào được kiểm tra, có lượt AI rà soát riêng. Chưa bảo đảm tính đúng ngữ nghĩa.

- AI phân tích không được viết khắc phục. Khắc phục chỉ nằm ở phần trích nguyên văn OWASP có kiểm tra phạm vi.

- Việc cho phép truy xuất khắc phục vẫn dựa trên CWE và bằng chứng không rỗng, không phải đánh giá độ mạnh bằng chứng.

- Dữ liệu gửi Gemini gồm metadata và tối đa 8 đoạn bằng chứng, mỗi đoạn 2400 ký tự; che một số dạng token/mật khẩu phổ biến, không bảo đảm loại hết dữ liệu nhạy cảm. Bằng chứng gốc giữ trong báo cáo cục bộ.

Tổng quan AI

Diễn giải AI đã qua kiểm tra nguồn và một lượt AI rà soát; chưa được xác minh thủ công.

Diễn giải phát hiện: Cơ chế quét ghi nhận một cảnh báo loại scanner_alert mang nhãn Reflected XSS (synthetic) với mã CWE-79, được cấp mức độ high từ nguồn kiểm thử và có chứa đoạn OWASP, với tổng số lượng là 1 mục ghi nhận thuộc phạm vi in_scope và chưa qua xác minh độc lập. [F1]

Thông tin còn thiếu / giới hạn: Cảnh báo được ghi nhận chưa qua xác minh độc lập từ dữ liệu nguồn. [F1]

Trích đoạn căn cứ đầu vào (đã che một số dữ liệu nhạy cảm):

[F1] ID BURP-0: Reflected XSS (synthetic); CWE CWE-79; mức độ do kiểm thử cung cấp high; loại scanner_alert; 2 mục bằng chứng, chưa xác minh độc lập; scope in_scope; có đoạn OWASP: True.

[F1] chưa xác minh độc lập

BURP-0 - Reflected XSS (synthetic)

Công cụ / nguồn: Burp Suite

Loại bản ghi: scanner_alert

Mức độ từ kiểm thử: high

Phân loại từ kiểm thử: CWE-79

Vị trí: https://example.test/search

Tham chiếu đầu vào: input.scan#/issues/issue[0]

Phạm vi OWASP Top 10:2025

Có ánh xạ trực tiếp CWE trong OWASP Top 10:2025; đây không phải xác nhận lỗ hổng thực tế.

Nhóm: A05:2025 Injection

https://top10.owasp.org/2025/A05_2025-Injection/

Phân tích

Kiểm thử cung cấp 2 mục bằng chứng. Giữ nguyên mức độ và phân loại từ đầu vào; chưa xác minh độc lập lỗ hổng. Có ánh xạ trực tiếp CWE trong OWASP Top 10:2025; đây không phải xác nhận lỗ hổng thực tế.

Diễn giải AI

Diễn giải AI đã qua kiểm tra nguồn và một lượt AI rà soát; chưa được xác minh thủ công.

Diễn giải phát hiện: Cong cu kiem thu cung cap ten phat hien la Reflected XSS (synthetic) tai vi tri https://example.test/search voi muc do high va phan loai la scanner_alert kem theo ma CWE-79. [M1, M2, M3]

Diễn giải phát hiện: Bang chung dau vao gom hai muc chua duoc xac minh doc lap, bao gom chi tiet van de va phan hoi HTTP 200 OK voi ky hieu phan hoi. [M4, E1, E2]

Thông tin còn thiếu / giới hạn: Cac phat hien la thong tin tu cong cu quet va chua duoc xac minh doc lap. [M2, M4]

Trích đoạn căn cứ đầu vào (đã che một số dữ liệu nhạy cảm):

[M1] Tên phát hiện do kiểm thử cung cấp: Reflected XSS (synthetic)

[M2] CWE từ đầu vào: CWE-79; mức độ từ đầu vào: high; loại bản ghi: scanner_alert

[M3] Vị trí do kiểm thử cung cấp: https://example.test/search

[M4] Bằng chứng đầu vào: 2 mục. Chưa xác minh độc lập.

[E1] issueDetail: SYNTHETIC issue detail for parser test.

[E2] HTTP response: HTTP/1.1 200 OK

SYNTHETIC response marker

[M2] loại bản ghi: scanner_alert

[M4] Chưa xác minh độc lập.

Bằng chứng đầu vào

issueDetail: SYNTHETIC issue detail for parser test.

HTTP response: HTTP/1.1 200 OK

SYNTHETIC response marker

Hướng dẫn khắc phục theo OWASP

Hướng dẫn nguyên văn OWASP (tiếng Anh; AI chỉ chọn đoạn)

When you use a modern web framework, you need to know how your framework prevents XSS and where it has gaps. There will be times where you need to do something outside the protection provided by your framework, which means that Output Encoding and HTML Sanitization can be critical. OWASP will be producing framework specific cheatsheets for React, Vue, and Angular.

Điều kiện áp dụng: Đoạn nguyên văn tiếng Anh do AI chọn; cần đối chiếu với công nghệ và ngữ cảnh thực tế. Không phải bản vá đã kiểm chứng.

Nguồn: Cross Site Scripting Prevention Cheat Sheet

https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

Mục: Cross Site Scripting Prevention Cheat Sheet / Framework Security

Nguồn cục bộ: Cross_Site_Scripting_Prevention_Cheat_Sheet.md | ký tự 1517:1883

Đối chiếu nguồn: Chưa duyệt thủ công | S7

Hướng dẫn nguyên văn OWASP (tiếng Anh; AI chỉ chọn đoạn)

In order for an XSS attack to be successful, an attacker must be able to insert and execute malicious content in a webpage. Thus, all variables in a web application needs to be protected. Ensuring that **all variables go through validation and are then escaped or sanitized is known as **perfect injection resistance**. Any variable that does not go through this process is a potential weakness. Frameworks make it easy to ensure variables are correctly validated and escaped or sanitized.**

Điều kiện áp dụng: Đoạn nguyên văn tiếng Anh do AI chọn; cần đối chiếu với công nghệ và ngữ cảnh thực tế. Không phải bản vá đã kiểm chứng.

Nguồn: Cross Site Scripting Prevention Cheat Sheet

https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

Mục: Cross Site Scripting Prevention Cheat Sheet / XSS Defense Philosophy

Nguồn cục bộ: Cross_Site_Scripting_Prevention_Cheat_Sheet.md | ký tự 1912:2403

Đối chiếu nguồn: Chưa duyệt thủ công | S8

Dấu vết tái lập

SHA-256 kiểm thử: d4930dcd688e4c65fd7b22d21b2d9dd96ab5a317694b708e30fa7c1483d4dc0e

SHA-256 kho hướng dẫn: 4920ce4715655ac875baf116bd88e640bb2dc0e9b1a0b150a2bdf82abebe71e2

Model AI: gemini-3.5-flash-lite